

README — KIT GQM+PRAGMATIC FISMA 2025

Guía de Inicio Rápido y Documentación Completa del Paquete

Diagnóstico de Madurez en Ciberseguridad con Trazabilidad GQM y Calidad Métrica PRAGMATIC

KIT GQM + PRAGMATIC + FISMA FY2025 — DIAGNÓSTICO DE MADUREZ
Ciberseguridad Institucional · España · Métricas de Calidad Verificada
Versión 1.0 · Abril 2026

¿QUÉ ES ESTE KIT Y EN QUÉ SE DIFERENCIA DEL KIT FISMA BASE?

El **Kit GQM+PRAGMATIC FISMA 2025** es la evolución metodológica del Kit FISMA base. Mientras el kit base responde a la pregunta "¿en qué nivel de madurez estamos?", este kit añade dos capas críticas de rigor:

1.

GQM (Goal-Question-Metric): ¿Por qué medimos cada métrica? ¿A qué objetivo estratégico sirve? Sin trazabilidad desde los objetivos nacionales hasta los datos técnicos, una métrica es un número sin propósito.

2.

PRAGMATIC: ¿Podemos confiar en cada métrica? Las 9 preguntas de Brotby & Hinson (2013) evalúan si una métrica es Predictiva, Relevante, Accionable, Genuina, Significativa, Precisa, Oportuna, Independiente y Rentable. Un IGM construido sobre métricas poco fiables no es un diagnóstico — es un espejo empañado.

GQM (Goal-Question-Metric): ¿Por qué medimos cada métrica? ¿A qué objetivo estratégico sirve? Sin trazabilidad desde los objetivos nacionales hasta los datos técnicos, una métrica es un número sin propósito.

PRAGMATIC: ¿Podemos confiar en cada métrica? Las 9 preguntas de Brotby & Hinson (2013) evalúan si una métrica es Predictiva, Relevante, Accionable, Genuina, Significativa, Precisa, Oportuna, Independiente y Rentable. Un IGM construido sobre métricas poco fiables no es un diagnóstico — es un espejo empañado.

El resultado diferencial: El **IGM ponderado por PRAGMATIC**, que reduce automáticamente el peso de las métricas menos fiables en el cálculo del índice global. Es posible que el IGM-PRAGMATIC de su organización sea inferior al IGM simple — y eso, paradójicamente, es buena noticia: significa que ahora saben la verdad.

ESTRUCTURA DEL KIT: LOS 7 DOCUMENTOS

kit-gqm-pragmatic-fisma-2025/

- (a) gqm-pragmatic-marco.md
Marco integrativo GQM+PRAGMATIC aplicado a los 10 dominios FISMA FY2025
10 objetivos · 29 preguntas · 25 métricas · Scores PRAGMATIC por dominio
- (b) matriz-pragmatic.md
Matriz completa: 25 métricas × 9 criterios PRAGMATIC (225 puntuaciones)
Rankings, análisis por criterio, mapa de calor, recomendaciones de mejora
- (c) narrativa-gqm-pragmatic.md
Por qué fallan las métricas de ciberseguridad y cómo GQM+PRAGMATIC lo resuelve
Para directivos, investigadores y policy-makers
- (d) mapeo-gqm-normativo.md
Tabla maestra: cada métrica → Objetivo GQM → Pregunta → FISMA → ENS → NIS2 →
NIST SP → ENCS
Umbrals de efectividad L3/L4/L5 para las 25 métricas
- (e) plantilla-igm-pragmatic-excel.md
Diseño del libro Excel de 10 pestañas con IGM ponderado PRAGMATIC + ROSI
verificado
Fórmulas completas para implementación directa
- (f) reporte-ejecutivo-gqm-ppt.md
Plantilla PowerPoint de 20+6 diapositivas con el doble diagnóstico IGM Simple
vs. PRAGMATIC
- (g) README-gqm-pragmatic.md
Este fichero

LA INNOVACIÓN CENTRAL: EL IGM PONDERADO POR PRAGMATIC

¿Por qué un IGM ponderado?

El IGM convencional trata todas las métricas como igualmente fiables. En la práctica, hay una diferencia enorme entre:

- CM-2 (Patch MTTP): Score PRAGMATIC 76/90 — métrica objetiva, automatizable, directamente accionable, difícilmente manipulable.
- ST-1 (Training Completion): Score PRAGMATIC 61/90 — mide actividad, no resultado; genuinidad baja; puede inflarse fácilmente.

Si ambas contribuyen igual al IGM, el resultado es una media ponderada de datos fiables e infiables. El IGM-PRAGMATIC aplica un factor de descuento a las métricas menos fiables, produciendo un índice más honesto.

La fórmula (simplificada):

El IGM-PRAGMATIC pondera cada puntuación de madurez por el factor de calidad PRAGMATIC de la métrica correspondiente:

- Una métrica con score 77/90 contribuye con ~86% de su valor nominal
- Una métrica con score 59/90 contribuye con ~66% de su valor nominal

Implicación práctica: Para mejorar el IGM-PRAGMATIC no sólo hay que mejorar la madurez — también hay que mejorar la calidad de cómo se mide esa madurez. Ambas son inversiones legítimas y complementarias.

DESCRIPCIÓN DETALLADA DE CADA DOCUMENTO

(a) Marco Integrativo GQM+PRAGMATIC — [gqm-pragmatic-marco.md](#)

10 objetivos GQM formulados con la plantilla canónica (Basili et al.):

Cada objetivo incluye: propósito, objeto de medición, atributo de calidad, perspectiva de la parte interesada y contexto organizacional.

29 preguntas GQM en tres tipos:

- Tipo 1 (Caracterización): ¿Cuál es el estado actual de X?
- Tipo 2 (Logro): ¿En qué medida se alcanza el objetivo?
- Tipo 3 (Mejora): ¿Qué tendencia muestra X?

25 métricas FISMA FY2025 con:

- Dato requerido y unidad de medida
- Umbral de efectividad (nivel L4)
- Score PRAGMATIC resumido y criterio más débil identificado

Árbol GQM completo: Visualización de la trazabilidad completa en formato texto estructurado.

(b) Matriz de Evaluación PRAGMATIC — [matriz-pragmatic.md](#)

Tabla principal: 31 filas × 12 columnas (25 métricas + 9 criterios + score total + calificación ★)

Análisis por criterio:

- **Predictivo (P):** Las métricas de resultado (MTTD, MTTC, phishing click rate) son más predictivas que las de proceso
- **Relevante (R):** 15 de 25 métricas tienen R=9; la relevancia normativa es prácticamente universal
- **Accionable (A):** Las 9 métricas de Categoría A tienen A ≥ 8; acción inmediata y clara ante valor bajo
- **Genuino (G):** El criterio más débil del conjunto (promedio 7.0); riesgo sistémico de métricas proxy
- **Significativo (M):** Métricas de resultado son más significativas para directivos que métricas técnicas
- **Preciso (Ac):** Las métricas automatizables (CM-2, IDAM-1, ISCM-2) tienen los mejores scores
- **Oportuno (T):** Segundo criterio más débil (promedio 7.0); ciclos anuales inadecuados para riesgos dinámicos
- **Independiente (I):** Riesgo en métricas autoevaluadas; solución: auditoría externa y automatización
- **Rentable (C):** Tercer criterio más débil; ZTA y CTI son costosas de implementar correctamente

Ranking completo de las 25 métricas (de mayor a menor score PRAGMATIC).

Mapa de calor: 10 módulos × 9 criterios con codificación rojo/ámbar/verde.

(c) Narrativa Explicativa — [narrativa-gqm-pragmatic.md](#)

Cuatro partes:

1. El problema: por qué las métricas de ciberseguridad fallan (métricas huérfanas, proxy, compliance washing)
2. La solución: cómo funciona GQM+PRAGMATIC como sistema integrado
3. El contexto español: el momento regulatorio (ENS + NIS2 + ENCS 2025) y la heterogeneidad autonómica
4. Cómo usar el kit: para el CISO, el investigador y el policy-maker

Audiencia: Directivos, investigadores, policy-makers, comunicadores.

(d) Mapeo GQM a Normativa — [mapeo-gqm-normativo.md](#)

Tabla maestra de trazabilidad completa: 25 métricas × 10 columnas:

ID Métrica | Nombre | Objetivo GQM | Pregunta GQM | Función CSF 2.0 | Score PRAGMATIC | ENS | NIS2 | NIST SP | Eje ENCS

Tablas inversas:

- ENS artículo a artículo → qué métricas lo cubren y score PRAGMATIC medio
- NIS2 artículo a artículo → cobertura de métricas
- Funciones CSF 2.0 → score PRAGMATIC promedio por función

Tabla de umbrales: L3/L4/L5 para las 25 métricas con fuente del umbral.

(e) Plantilla Excel IGM-PRAGMATIC — [plantilla-igm-pragmatic-excel.md](#)

10 pestañas del libro FISMA_GQM_PRAGMATIC_IGM_ROSI_v1.xlsx:

Pestaña	Función	Celdas clave
PORTADA	Instrucciones y navegación	—
DATOS_ORG	Perfil organizacional (14 campos)	B3:B14
PRAGMATIC_SCORES	225 scores editables (25×9)	C2:K26
RESPUESTAS_GQM	29 respuestas A-E con codificación	C2:C30
IGM_SIMPLE	IGM convencional para comparación	B15
IGM_PRAGMATIC	IGM ponderado — módulo central	B30
ROSI_CALCULO	ROSI con ajuste de fiabilidad PRAGMATIC	B27-B32
POAM_GQM	Plan de acción con trazabilidad GQM	A15:P1000
DASHBOARD	Panel visual integrado	—
BENCHMARKS	Referencias sectoriales España + EU + FISMA EE.UU.	—

Fórmulas innovadoras:

- Factor de confianza PRAGMATIC: $\text{Score_PRAGMATIC_i} / 90$
- IGM-PRAGMATIC: suma ponderada con factor de confianza
- ROSI ajustado: ALE corregido por fiabilidad de métricas
- Prioridad POA&M combinada: urgencia normativa $\times$ impacto IGM $\times$ factor PRAGMATIC

(f) Reporte Ejecutivo PowerPoint — [reporte-ejecutivo-gqm-ppt.md](#)

20 diapositivas principales + 6 opcionales:

Bloque	Diapositivas	Contenido
Contexto	1-4	Portada, problema, marco metodológico, criterios PRAGMATIC
Resultados	5-8	Doble IGM, radar dual, ranking PRAGMATIC, mapa de calor
Análisis	9-11	4 categorías de métricas, causa raíz G/T, top 5 hallazgos
Acción	12-14	ROSI verificado, hoja de ruta dual, marco normativo
Comparativa	15	Benchmarks internacionales con doble IGM
Decisión	16-20	4 decisiones del consejo, fuentes, glosario, FAQ, cierre

Diferencial visual: El "Gráfico Radar Dual" (IGM Simple vs. IGM PRAGMATIC) y el "Mapa de Calor PRAGMATIC" son los elementos visuales exclusivos de este kit que no están en el reporte FISMA base.

RELACIÓN ENTRE ESTE KIT Y EL KIT FISMA BASE

Dimensión	Kit FISMA Base	Kit GQM+PRAGMATIC
Pregunta central	¿En qué nivel estamos?	¿Cuánto podemos confiar en que estamos ahí?
Nº métricas	25 FISMA FY2025	25 FISMA FY2025 (las mismas, con evaluación de calidad)
IGM	Simple (media ponderada por módulo)	Doble: Simple + Ponderado por PRAGMATIC
Trazabilidad	Normativa (ENS/NIS2)	GQM desde objetivos nacionales + normativa
Audiencia principal	CISO, auditores, directivos	CISO, investigadores, policy-makers
Complejidad	Alta	Muy alta
Tiempo de implementación	2-4 semanas	4-8 semanas (primera vez)
Valor diferencial	Diagnóstico de cumplimiento	Diagnóstico de calidad del diagnóstico

Recomendación: Usar el Kit FISMA Base para el primer diagnóstico rápido. Implementar el Kit GQM+PRAGMATIC en la segunda iteración (6-12 meses después) cuando el equipo esté familiarizado con los conceptos y tenga datos históricos para comparar.

BASES NORMATIVAS Y TEÓRICAS

Documento	Organismo	Año	Rol en el kit
FY2025 IG FISMA Reporting Metrics v2.0	CIGIE / OMB / CISA	3 abril 2025	Marco métrico primario (25 indicadores)
OMB Memorandum M-25-04	OMB / White House	14 enero 2025	Guía de implementación FY2025
NIST Cybersecurity Framework 2.0	NIST	Febrero 2024	Estructura de funciones
NIST SP 800-53 Rev. 5	NIST	Septiembre 2020	Controles técnicos de referencia
NIST SP 800-207 (Zero Trust)	NIST	Agosto 2020	Métricas ZTA
CISA Zero Trust Maturity Model v2.0	CISA	Abril 2023	Niveles de madurez ZTA
Goal-Question-Metric Approach	Basili, Caldiera, Rombach	1994	Marco GQM Level 1-3
GQM+Strategies	Basili et al.	2014	Extensión a estrategias nacionales
PRAGMATIC Security Metrics	Brotby & Hinson (CRC Press)	2013	Sistema de evaluación de calidad métrica
Real Decreto 311/2022 (ENS)	Gobierno de España	3 mayo 2022	Marco normativo nacional
Directiva UE 2022/2555 (NIS2)	Parlamento Europeo	14 diciembre 2022	Marco europeo
Anteproyecto Ley Coord. Ciberseguridad	DSN / Gobierno España	14 enero 2025	Transposición NIS2 en curso
ENCS España 2025	DSN / Gobierno España	2025	Estrategia nacional; ejes GQM+Strategies
ENISA NIS Investments 2025	ENISA	Diciembre 2025	Benchmarks europeos
CCN-CERT Informe Ciberamenazas 2025	CCN-CERT / CNI	2025	Datos de contexto nacional

VERSIONES FUTURAS

Versión	Fecha estimada	Contenido previsto
v1.1	Q3 2026	Calibración de scores PRAGMATIC con datos empíricos del piloto; ajuste de benchmarks sectoriales
v2.0	2027	Actualización a FY2026 FISMA Metrics; incorporación de métricas PQC (FIPS 203/204/205); extensión a sector privado NIS2; integración con ISO 27001:2022
v3.0	2028	Versión con IA asistida: scoring PRAGMATIC semi-automatizado mediante análisis de calidad de datos reales de herramientas (SIEM, EDR, IAM)

LICENCIA

Distribuido bajo **Creative Commons Attribution-NonCommercial-ShareAlike 4.0 International (CC BY-NC-SA 4.0)**:

-  Uso académico, investigación, docencia y autodiagnóstico no comercial
-  Adaptación y mejora con atribución
-  Uso comercial sin autorización expresa
-  Cita requerida: "Kit GQM+PRAGMATIC FISMA 2025 — Diagnóstico de Madurez en Ciberseguridad Institucional, v1.0, Abril 2026. Basado en FY2025 IG FISMA Metrics v2.0, NIST CSF 2.0, ENS RD 311/2022, NIS2, GQM (Basili et al. 1994) y PRAGMATIC (Brotby & Hinson 2013)."

"Lo que no se mide, no se gestiona.
Lo que se mide mal, se gestiona peor.
Lo que se mide bien y se entiende,
por fin se puede mejorar."

Kit GQM+PRAGMATIC FISMA 2025 · v1.0 · Abril 2026